Framework CALDERA: Emulação Autônoma de Adversários

O CALDERA™ é uma plataforma de emulação de adversários construída sobre o framework MITRE ATT&CK. Diferente de execuções manuais, o CALDERA permite criar operações autônomas onde "agentes" tomam decisões baseadas em objetivos predefinidos.

Arquitetura e Componentes Chave

Para entender o CALDERA, é preciso dominar sua terminologia interna:

1. Agentes (Os Braços)

São programas instalados nos alvos que se comunicam com o servidor central para receber instruções.

- Sandcat (54ndc47): O agente padrão escrito em Go, altamente flexível (HTTP, DNS, etc.).
- Manx: Focado em conexões TCP (Reverse Shell).
- Ragdoll: Utiliza formulários HTML para camuflar o tráfego de comando e controle (C2).

2. Abilities e Adversaries (O Cérebro)

- Ability (Habilidade): É a implementação técnica de uma TTP (ex: um comando PowerShell para listar usuários).
- Adversary (Adversário): Um perfil que agrupa várias habilidades para simular um grupo específico (ex: Perfil "Alice 2.0").

3. Operações (A Execução)

Uma operação une um Adversário a um Grupo de Agentes. Durante a operação, o Planner decide a ordem das ações:

- Atomic: Segue a ordem linear.
- Batch: Executa tudo de uma vez.
- Buckets: Organiza por táticas do MITRE (Discovery, Persistence, etc.).

Conceitos Operacionais Avançados

Conceito	Descrição Técnica
Facts (Fatos)	Variáveis descobertas durante o ataque (ex: um hostname ou uma senha encontrada).
Obfuscators	Técnicas para "mascarar" os comandos e evitar detecção por antivírus/EDR.
Jitter	O intervalo de tempo aleatório entre as comunicações do agente para evitar padrões de tráfego.

Plugins de Destaque
O CALDERA é modular. Alguns plugins expandem suas capacidades:

- Human: Gera tráfego e atividades de usuário "reais" (abrir pastas, navegar na web) para tornar o laboratório mais realista.
- Training: Um sistema de certificação gamificado dentro da própria ferramenta.
- Response: Focado em Blue Team Autônomo, respondendo a incidentes de forma automática.

Deployment e Execução no CALDERA

Nesta etapa, realizamos a implantação de um servidor C2, a infecção de um alvo via agente persistente e a execução de uma operação de enumeração automatizada.

1. Configuração do Servidor e Agente

A operação começou com a inicialização do servidor em ambiente virtual Python. O agente escolhido foi o Manx (via TCP), devido à sua capacidade de fornecer uma shell reversa robusta.

- Tática de Evasão: Durante a configuração, o binário do agente foi renomeado de manx.go para chrome.exe. Essa técnica de Masquerading (T1036) visa camuflar o agente como um processo legítimo do Google Chrome no Gerenciador de Tarefas.
- Conectividade: O endereço IP padrão de configuração inicial do CALDERA é 0.0.0.0, exigindo a alteração manual para o IP do AttackBox para garantir que o agente saiba para onde "ligar de volta".

2. Perfil do Adversário: Enumerador
Para este exercício, foi utilizado o perfil Enumerador. Este perfil é focado na fase de Discovery (Descoberta) do MITRE ATT&CK.

- Composição: O perfil possui 5 habilidades (Abilities) distintas.
- Análise Técnica: Validamos a habilidade de "Tasklist Process Enumeration", que utiliza o comando nativo tasklist via executor PowerShell para listar todos os processos ativos no alvo.

3. Execução da Operação

A operação foi configurada para o grupo Red (Vermelho), garantindo que as ações não afetassem agentes de defesa (Azuis).

Resultados e Telemetria

Após o início, o agente executou sequencialmente as ordens do servidor. A análise dos resultados permitiu validar quais comandos retornaram dados úteis:

- Sucesso: Comandos como tasklist e systeminfo geraram logs detalhados sobre o ambiente da vítima.
- Habilidade sem Saída: Durante a operação, a habilidade Network Configuration Enumeration (ou similar, dependendo da versão) pode não gerar saída caso as

permissões do agente sejam restritas ou o comando não encontre interfaces ativas no contexto executado.

Conclusão

A utilização do CALDERA demonstrou como um atacante pode automatizar a coleta de informações sem intervenção manual constante. Para o Blue Team, isso reforça a necessidade de monitorar não apenas o nome dos processos (como o chrome.exe falso), mas também o comportamento de rede (conexões TCP em portas não padronizadas).

Emulação de Adversário

Resumo Executivo

Esta documentação detalha a criação de um Perfil de Adversário Customizado no framework MITRE CALDERA. O foco central foi a adaptação de Táticas, Técnicas e Procedimentos (TTPs) para um ambiente restrito (sem conectividade externa), simulando uma cadeia de ataque completa desde o Acesso Inicial até a Exfiltração.

Desafios Superados & Engenharia de Solução

Para garantir a execução em rede isolada, foram realizadas modificações críticas no código das habilidades:

- Adaptação de Infraestrutura: Substituição de fontes externas (GitHub) por um servidor de arquivos local em Python 3 (AttackBox).
- Customização de Payload: Refatoração de comandos PowerShell para utilizar variáveis de ambiente dinâmicas ($env:TEMP), garantindo portabilidade.
- Desenvolvimento de Habilidade Zero-Day: Criação manual da técnica de Exfiltração via HTTP (T1048.003), utilizando fragmentação de dados em blocos hexadecimais de 20 bytes para evitar detecção por volume.

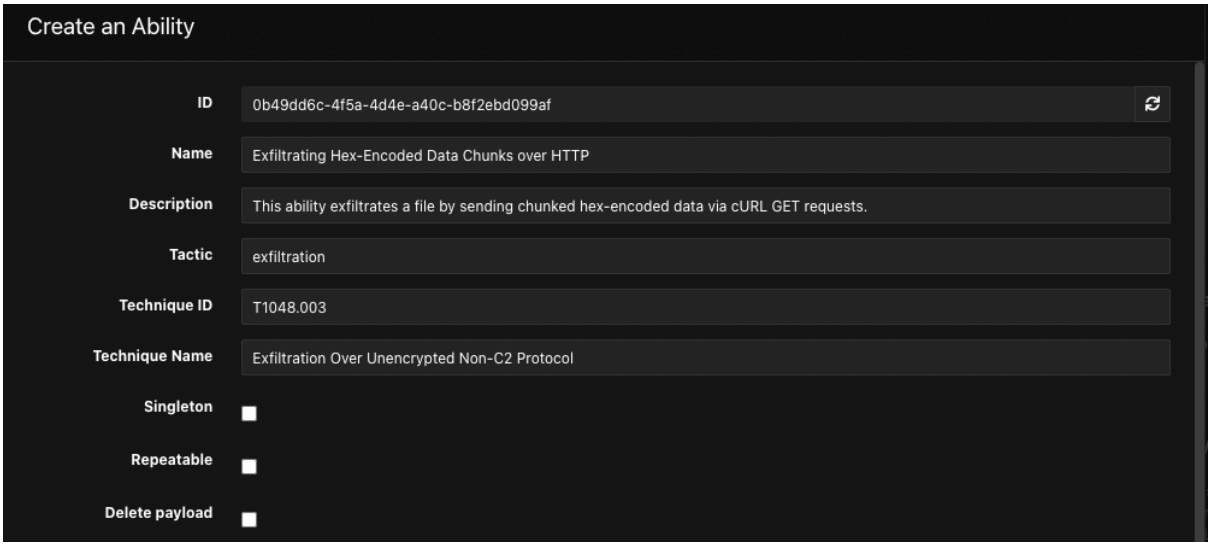
FAQ Técnico: Filtro de Inteligência

As perguntas abaixo validam a eficácia da operação e o domínio sobre os artefatos gerados:

1. Como a técnica de persistência via Winlogon (T1547.004) impacta o sistema?
    - Ela altera o registro do Windows para que o agente seja executado automaticamente no logon, garantindo continuidade sem nova interação do usuário.
2. Qual o diferencial da exfiltração hex-encoded sobre GET?
    - Transforma arquivos binários em strings de texto simples enviadas via URL, mimetizando tráfego web legítimo e dificultando a inspeção de pacotes (DPI).
3. Por que o uso de WMI (T1047) é estratégico nesta cadeia?
    - Permite a execução de processos de forma lateral e discreta, utilizando ferramentas nativas do Windows (Living off the Land) para reduzir o rastro em disco.

Matriz de Habilidades (Kill Chain)

Tática	Técnica	Ação Realizada
Acesso Inicial	T1566.001	Phishing via anexo com Macro.
Execução	T1047	Comando codificado via WMI.
Persistência	T1547.004	Modificação de Chave Shell Winlogon.
Coleta	T1074.001	Staging de dados via Compress-Archive.
Exfiltração	T1048.003	Exfiltração de blocos Hex via HTTP.



Exfiltrando blocos de dados codificados em hexadecimal sobre HTTP

Relatório de Observabilidade e Detecção

Visão Geral da Análise

Após a execução da cadeia de ataque, o foco deslocou-se para a análise forense e telemetria de endpoint. Utilizei ferramentas de monitoramento avançado para correlacionar as ações do agente CALDERA com os registros gerados no sistema operacional, validando a eficácia das regras de detecção.

Metodologia de Investigação (Blue Team)

Para uma análise limpa e precisa, apliquei as seguintes táticas de triagem:

- Isolamento de Execução: Configuração do estado de operação para Pause on Start, permitindo a análise individual de cada link (habilidade).
- Higiene de Logs: Uso do módulo Clear-WinEvent para resetar a telemetria entre cada técnica, eliminando falsos positivos.
- Monitoramento em Tempo Real: Implementação do script PowerSiem.ps1 para visualização instantânea de eventos Sysmon (ID 1, 11, 13, etc.).

Matriz de Detecção & Regras Sigma

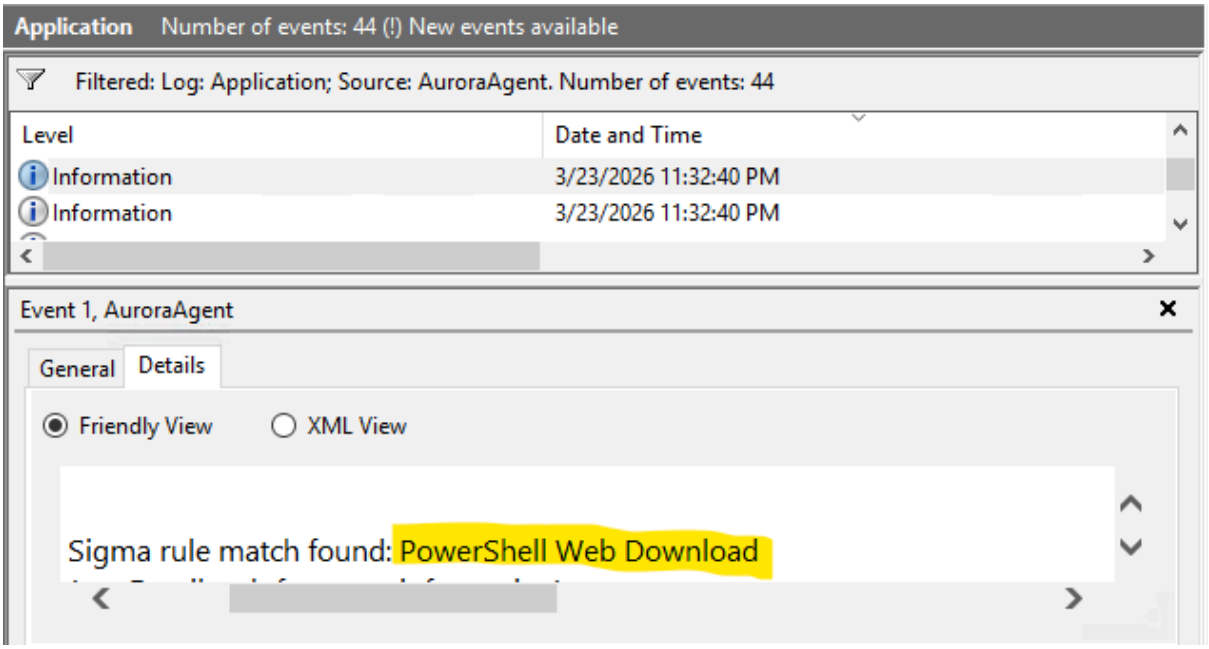
Abaixo, os principais gatilhos identificados pelo Aurora EDR durante a emulação:

Técnica Emulada	Ferramenta de Log	Indicador de Comprometimento (IoC)	Regra Sigma Ativada
WMI Query	Sysmon (ID 1)	CommandLine com Base64/Encoded	Suspicious WMI Execution
Winlogon Shell	Sysmon (ID 13)	Alteração em HKLM\...\Winlogon\Shell	Registry Persistence Detection
Phishing Download	Aurora EDR	Uso de Invoke-WebRequest via PSH	Suspicious PowerShell Web Request
Data Staging	Aurora EDR	Compress-Archive em diretórios Temp	Zip Folder via PowerShell

Insights de Engenharia de Detecção

Filtro das observações mais críticas para recrutadores:

1. Rastreabilidade do Agente: Identifiquei que todos os ataques derivam do processo pai C:\Users\Public\chrome.exe. Em um cenário real, isso indica um binário legítimo sendo usado como proxy para comandos maliciosos.
2. Análise de Strings Suspeitas: A detecção da sexta habilidade (Exfiltração) ocorreu devido ao campo Match_Strings, que sinalizou a manipulação de strings como join ''; $split, um padrão comum em scripts de exfiltração de dados.
3. Persistência de Registro: O evento Sysmon ID 13 foi crucial para mapear a modificação da chave Winlogon, demonstrando como um atacante garante o retorno ao sistema após o reboot.



Relatório de Defesa Ativa e Resposta a Incidentes

Visão Geral da Operação Azul (Blue Team)

Diferente das operações ofensivas, a Operação Azul utiliza o conceito de Defensores. O objetivo foi implementar um perfil de Resposta a Incidentes capaz de monitorar o sistema continuamente, identificar artefatos maliciosos (como shells reversos) e executar contra-medidas automáticas.

Arquitetura do Plugin de Resposta

As habilidades de defesa são estruturadas em quatro pilares estratégicos:

1. Configuração: Estabelece a linha de base (baselines) do sistema.
2. Detecção: Monitoramento contínuo e repetível de comportamentos suspeitos.
3. Resposta: Ações diretas de remediação (ex: encerrar processos, bloquear portas).
4. Caça (Hunting): Busca ativa por Indicadores de Comprometimento (IOCs).

Inteligência de Dados: Fontes e Fatos

O sucesso da automação no CALDERA depende da correlação de Fatos (dados identificáveis) e Fontes (grupos de fatos).

- Fato Crítico: remote.port.unauthorized
- Aplicação Prática: Configuramos portas específicas (7010, 7011, 7012 e a customizada 4444) como não autorizadas.
- Dinâmica de Desbloqueio: A detecção de uma conexão na porta 4444 gera um novo fato que "desbloqueia" a habilidade de resposta para criar uma regra de firewall ou derrubar o processo.

Fluxo de Resposta a Incidentes (Cenário Real)

Durante a emulação de um Shell Reverso via nc.exe na porta 4444, o perfil de defesa executou a seguinte sequência lógica:

- Detecção: A habilidade Find unauthorized processes varreu as conexões TCP e identificou o PID (Process ID) associado à porta 4444.
- Análise de Vínculo: O sistema correlacionou o processo detectado com habilidades de resposta pendentes.
- Remediação Automática:
    - Firewall: Ativação da regra Enable Outbound TCP/UDP firewall rule.
    - Contenção: Execução de habilidades como Kill Rogue Process para encerrar a ameaça.

Insights de Engenharia de Resposta

Pontos fundamentais para recrutadores sobre sua capacidade técnica:

1. Automação Condicional: Demonstrei que a resposta só ocorre após a validação do fato. Isso evita "falso-positivos" que poderiam derrubar serviços legítimos.
2. Operação em Lote (Batch Mode): O uso do Planejador em modo Batch permite que o defensor reavalie o ambiente constantemente, criando um ciclo de defesa resiliente.
3. Higiene de Ativos: O uso de agentes específicos (Grupo: Azul) garante que as ferramentas de defesa não interfiram na infraestrutura de ataque durante um exercício de Purple Teaming.

Engenharia de Emulação: Caso APT41 (Double Dragon)

Objetivo da Atividade

Simular uma cadeia de ataque completa baseada no grupo APT41, visando testar a resiliência de ambientes críticos e validar regras de detecção (Sigma/EDR) em uma rede isolada.

O que eu Simulei e Executei

Filtro das ações técnicas de maior impacto:

1. Acesso e Execução Ofuscada: Simulei a entrada via Phishing e utilizei WMI (Win32_Process) de forma ofuscada para evadir defesas que monitoram apenas execuções diretas de processos.
2. Persistência Híbrida: Configurei tarefas agendadas via PowerShell e criei novos usuários via CMD, garantindo que o atacante mantenha o acesso mesmo após reinicializações.
3. Evasão de Defesa (Anti-Forense): Executei a limpeza sistemática de logs de eventos do Windows (wevtutil), simulando o comportamento de agentes que tentam apagar seus rastros digitais.

4. Descoberta e Coleta: Realizei a enumeração de arquivos e diretórios sensíveis no host, preparando o ambiente para a exfiltração de dados.

Questões Chave e Evidências Técnicas

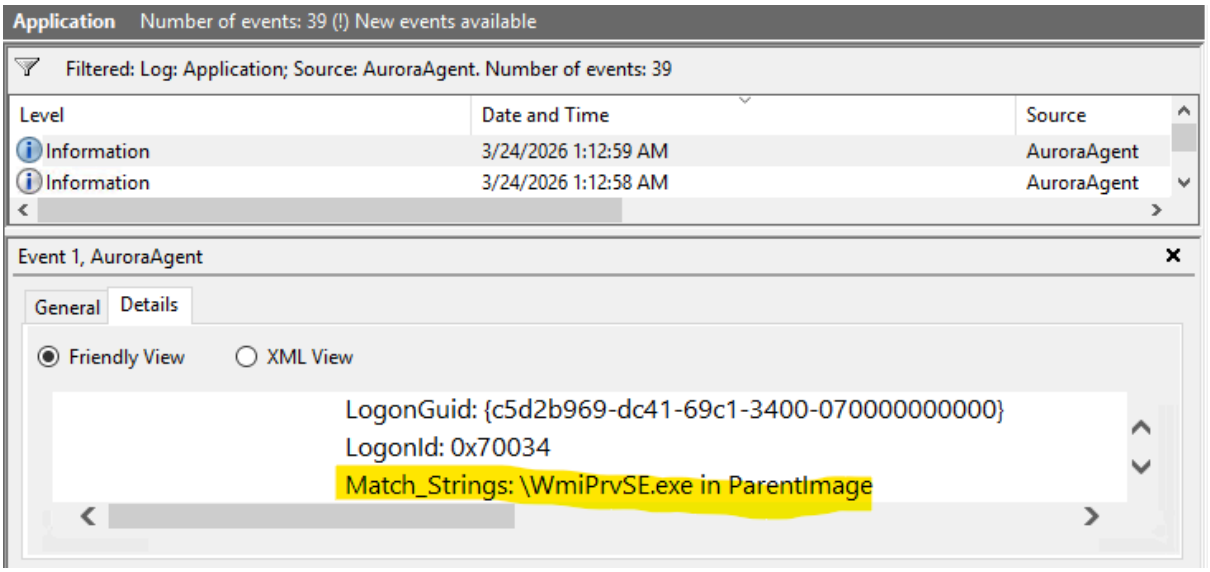
Selecionei as detecções mais críticas que provam a eficácia da monitoração:

1. Detecção de Phishing e Payload Inicial

- Cenário: O download do anexo de phishing gerou arquivos residuais além do script principal.
- Evidência: O arquivo identificado no TargetFilename confirmou a entrega do artefato malicioso no diretório temporário.

2. Identificação de Comandos Ofuscados (WMI)

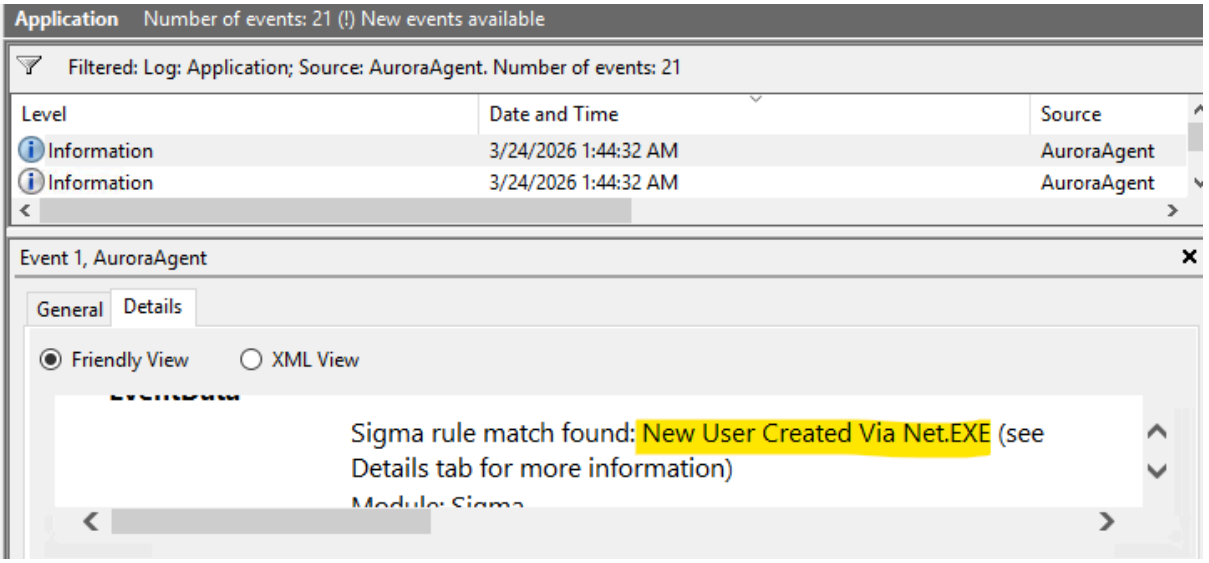
- Cenário: Como o EDR detectou o uso de Win32_Process?
- Regra Sigma: A regra sinalizou através do MatchString específico, capturando a tentativa de esconder a árvore de execução original.



3. Monitoramento de Administração de Contas

- Cenário: qual é o nome da regra Sigma que sinalizou a execução do comando "Criar um novo usuário" em um prompt de comando?

- Regra Sigma: Foi identificada uma tentativa de criação de usuário local via prompt, disparando um alerta de alta severidade para modificação de privilégios.



Conclusão Profissional

Esta atividade demonstrou que a defesa em profundidade, combinando Sysmon e regras Sigma, é capaz de detectar as TTPs do APT41 em diferentes estágios. Minha atuação permitiu validar que, mesmo com técnicas de ofuscação e anti-forense, os sinais deixados no sistema são suficientes para uma resposta a incidentes eficaz.